Final Technical Review

Review summary

This document evaluates the current main architecture after the Gateway/security/platform merges. The latest full-solution CI validation completed restore, Release build with --warnaserror, and dotnet test successfully. This proves compilation and the current unit-test scope are green; it does not mean real-infrastructure concurrency testing is complete.

Strengths

- MSSQL is the financial source of truth; Redis is not an authority for money correctness.
- Wallet transfer commits balances, idempotency, transaction and ledger state in one SQL transaction.
- Double-entry Debit = Credit is validated both in Domain and persisted SQL.
- Durable idempotency prevents duplicate money movement.
- External HTTP runs outside the financial SQL transaction.
- Fraud risk signals are derived from server state rather than trusted from the client.
- JWT plus durable sessions provide revocation checks for high-risk operations.
- YARP Gateway provides public auth, internal routing, rate limiting, health and load-balancing boundaries.
- Backend/provider business endpoints require a downstream service credential to reduce direct-bypass risk.
- Swagger is standardized across all Web APIs and disabled by default in production.
- Central package management and warnings-as-errors are enabled.
- xUnit v3 + Moq exist and CI executes tests.

Status of the previous request

- YARP Gateway: **completed**.
- Routing service traffic through Gateway: **implemented**; FinWallet provider adapters use /providers/*.
- Gateway JWT enforcement: **completed**.
- Load balancing / health / rate limiting / request limits: **completed**.
- Swagger on all APIs: **completed**.
- OWASP/API-abuse hardening: **completed at application level**; volumetric DDoS still requires edge/ingress/WAF deployment controls.
- MSSQL/Redis/HttpClient/YARP performance review: **completed**.
- Moving operational/tuning parameters into appsettings: **completed**.
- Unit-test mock verification: previously missing; **xUnit + Moq added**.
- Registration-to-transfer happy-path document: **completed**, with the public-funding gap documented explicitly.
- AI architecture decision narrative: **completed**.
- All maintained project documentation in TR+EN: **completed**.

Values intentionally not moved into appsettings

The request for “all parameterized elements” was applied to operational and tuning values. The following deliberately remain non-runtime-switch invariants:

- JWT signing algorithm;
- PBKDF2 V1 scheme/work-factor migration semantics;
- double-entry equality;
- financial decimal invariants;
- durable idempotency semantics;
- transaction/locking correctness rules.

Making these arbitrary configuration switches could weaken security or make existing persisted data unverifiable.

Open technical debt

1. Public BankDeposit and BankWithdrawal.
2. Durable FraudEvents/manual review.
3. Outbox/Inbox and reliable post-commit notification.
4. ReconciliationRuns/ReconciliationIssues.
5. Transaction-history/read model.
6. Centralized masked structured logging + OpenTelemetry/alerting.
7. Real MSSQL/Redis/YARP integration and concurrency test suite.
8. Public logout/session-revoke endpoint.
9. Dependency vulnerability/SBOM pipeline.
10. Production ingress/WAF/network-policy/TLS deployment hardening.

Recommended priority

1. BankDeposit;
2. BankWithdrawal + cutoff;
3. integration/concurrency tests;
4. Outbox/Inbox + notification;
5. FraudEvents/manual review;
6. transaction history;
7. reconciliation;
8. telemetry/operations hardening.

Final assessment

The current system is a solid financial-core/gateway baseline for a side project. It should not be described as a production-ready banking platform until funding/withdrawal, reconciliation, observability and real-infrastructure concurrency tests are complete.